



SOFTWARE ASSURANCE MATURITY MODEL

BENCHMARK REPORT

JUNE 2026

TABLE OF CONTENTS

What is SAMM3

SAMM Benchmark4

About the data5

How you can contribute5

Demographics6

 Geographic distribution6

 Industry Verticals7

 Assessment Types8

 Assessment Scopes9

 Number of Application Security People9

Overview10

Our Successes12

Our Challenges13

Insights and patterns15

 Maturity Level Analysis15

 Related Security Activities18

 Small Company Focus Areas18

 Large Company Challenging Areas19

Governance20

Design22

Implementation24

Verification26

Operations28

Taking Action30

The Making of this Report31

WHAT IS SAMM

SAMM stands for Software Assurance Maturity Model.

Our mission is to provide an effective and measurable way for all types of organizations to analyze and improve their software security posture. We want to raise awareness and educate organizations on how to design, develop, and deploy secure software through our self-assessment model. SAMM supports the complete software lifecycle and is technology and process agnostic. We built SAMM to be evolutionary and risk-driven, as there is no single recipe that works for all organizations.

SAMM is a prescriptive model, an open framework which is simple to use, fully defined, and measurable. The solution details are easy enough to follow even for non-security personnel. It helps organizations analyze their current software security practices, build a security program in defined iterations, show progressive improvements in secure practices, and define and measure security-related activities.

SAMM was designed with flexibility in mind so that small, medium, and large organizations using any development style can customize and adopt it. It provides a means of knowing where your organization is on its journey towards software assurance and understanding what is recommended to move to the next level of maturity.

SAMM does not insist that all organizations achieve the maximum maturity level in every category. Each organization can determine the target maturity level for each Security Practice that best fits it and adapt the available templates to its specific needs.

SAMM is based around 15 security practices grouped into 5 business functions. Every security practice contains a set of activities, structured into 3 maturity levels. Activities at a lower maturity level are typically easier to execute and require less formalization than those at a higher maturity level.

At the highest level, SAMM defines five business functions. Each business function is a category of activities that any organization involved with software development must fulfill to some degree.

Each business function has three security practices, areas of security-related activities that build assurance for the related business function.

Security practices comprise activities grouped into logical flows and divided into two streams. Streams cover different aspects of a practice and have their own objectives, aligning and linking activities across maturity levels.

For each security practice, SAMM defines three maturity levels. Each level has a more sophisticated objective with specific activities and stricter success metrics.

SAMM BENCHMARK

The SAMM Benchmark is dedicated to helping our users answer the critical questions “How am I doing?” and “What might be working for other similar organizations?” is a priority for the SAMM team. Our goal is to build a database that helps companies measure the maturity of their security development practices against industry standards, using variables such as vertical and company size. In turn, the information we collect can help the SAMM model evolve based on actual field data. As an added benefit, this project can facilitate research on secure development practices worldwide as universities and researchers analyze and interpret the information the community donates, providing valuable insights.

The end goal of the benchmark initiative is for companies to use the data to measure themselves against their peers in the industry. Our main hurdle at this point is gathering a sufficiently large dataset to ensure accurate comparisons while maintaining full anonymity for the contributing parties. As an added benefit, we’ll use the data to prioritize the publication of guidance for streams and activities.

In June 2024, we released the very first OWASP SAMM Benchmark data. Despite strong community interest in establishing a common benchmark, the number of submitted datasets has been very limited (25). The benchmark is heavily based on data provided by large organizations. The benchmark data and some of its interpretations were presented during SAMM User Days in Lisbon.

In September 2024, we released an updated OWASP SAMM Benchmark. The number of data sets remains quite limited (30). The benchmark dataset remains skewed towards large organizations. The SAMM Core team was able to slice the data and provide more granular information. The benchmark data and its interpretations were presented during SAMM User Day in San Francisco.

In November 2025, we released an updated OWASP SAMM Benchmark that included 68 data sets. More insights were uncovered and shared during the SAMM User Day at the Global AppSec DC conference. The data collection is heavily weighted toward large and small organizations, with limited representation from medium-sized orgs.

In June 2026, we are releasing this benchmark report, which contains information from 69 contributed data sets, and we seek to provide insight into how organizations have been working in the secure software space. Our goal is to encourage steady growth in the data so we can continue to improve the detail and applicability of insights from the data to help you with your secure development challenges.

ABOUT THE DATA

The data has been contributed from many different organizations around the world. Only basic demographic information is collected and kept with the scores that were contributed. The data is either from a trusted SAMM practitioner or directly from an organization source. We have a high level of confidence that the contributions are genuine and represent completed assessments. The assessments contributed range in date from 2020 to 2026, with most assessments completed between 2023 and 2026.

HOW YOU CAN CONTRIBUTE

SAMM Benchmark is an open-source, volunteer, community project that aims to collect, analyze, and provide insights into how organizations manage their secure development lifecycles. You can learn how to contribute in the Benchmark section of <https://owaspsamm.org>

DEMOGRAPHICS

For a data collection of 69 sets, there is a good distribution of demographics. The SAMM Benchmark attempts to strike a balance between providing enough information to be useful and not so much that organizations can be identified by the collected demographics. Since a SAMM assessment can be performed at the company, organizational, or team level, some companies have multiple assessments in the data collection.

Geographic distribution

In the current data set of 69 entries, 42% of the assessments are from companies identified as global. Assessments for European companies account for 39% of the total, with North America contributing 12%, and Asia-Pacific with 4%. There is a contribution from Latin America and one that declined to provide their geographic information. The reason we look at this is that different areas of the world are at different points in their secure development needs and experiences. Companies based outside of Europe need to start contributing to help provide more balanced insights in the data collection.

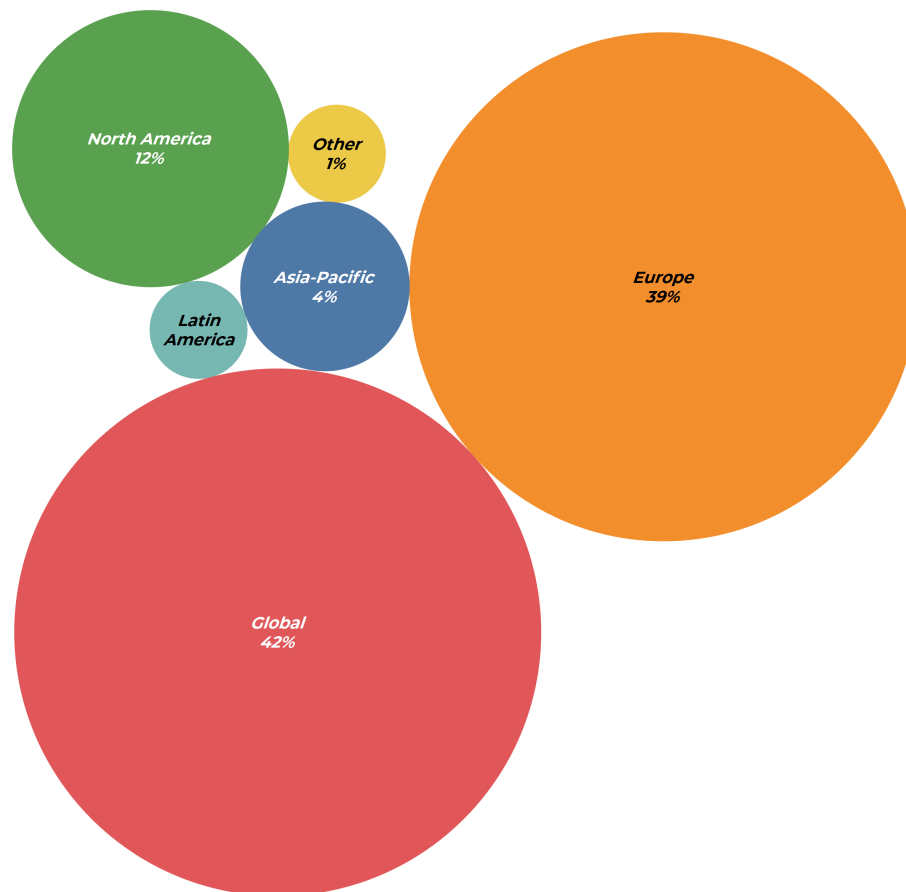


Figure 1: Geographic Distribution

Industry Verticals

43% of the contributed assessments are from companies that bridge multiple industry verticals. Independent Software Vendors contributed 17% of the assessments, with Manufacturing at 12%, Healthcare at 9%, and several others contributing 6% or fewer. Again, as the data collection grows, we plan to be able to filter the results by demographic information, including industry verticals, as various industries face distinct internal and external forces that would impact what they prioritize within their company’s secure development lifecycle.

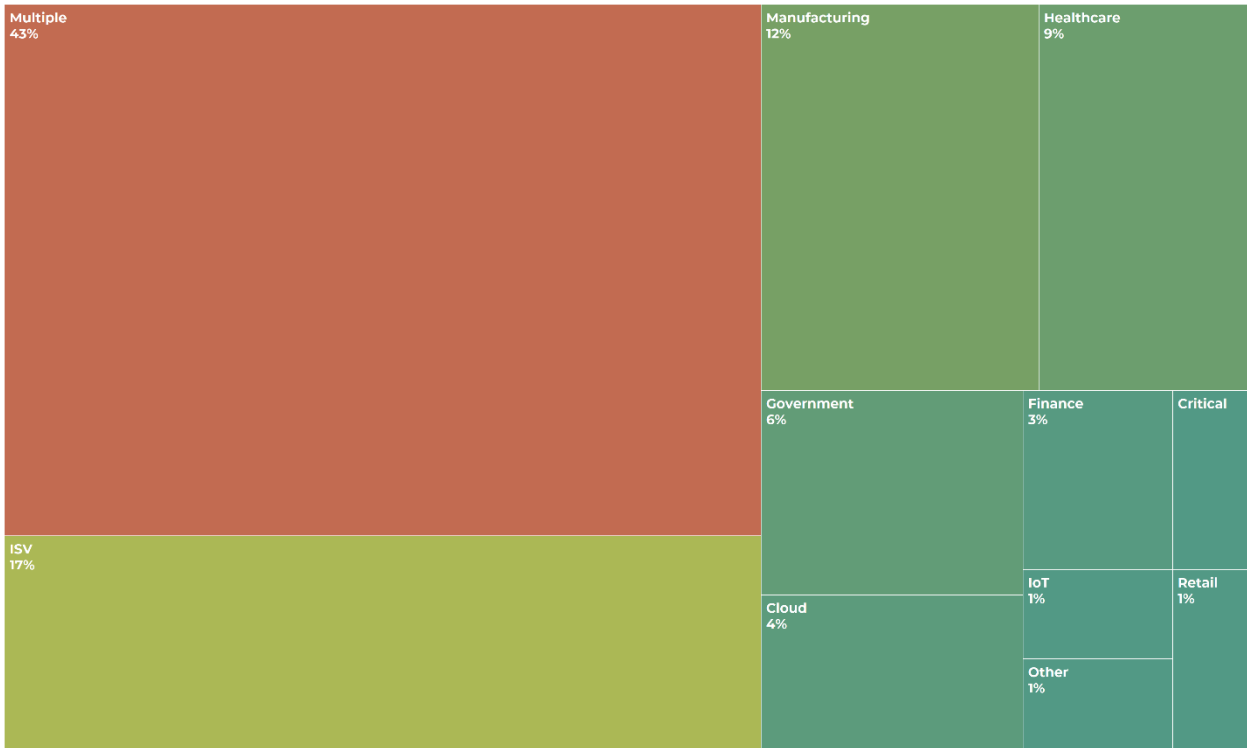
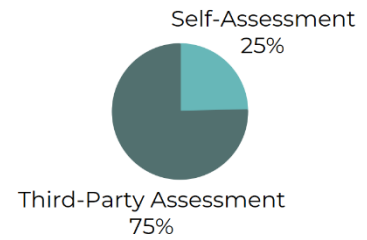


Figure 2: Industry Verticals

Assessment Types

The assessment type is also captured as part of the demographic information, because we believe there are differences between self-assessments and third-party assessments. 75% of the contributed assessments are from SAMM practitioners performing them on other companies.



The core team theorized that self-assessments would be higher because we believed people would give themselves the benefit of the doubt, given the incentives to achieve a higher score. In the current data collection, smaller companies self-assessed higher on average than third-party assessments indicated. However, medium and large companies' self-assessment scores were much lower than third-party assessments.

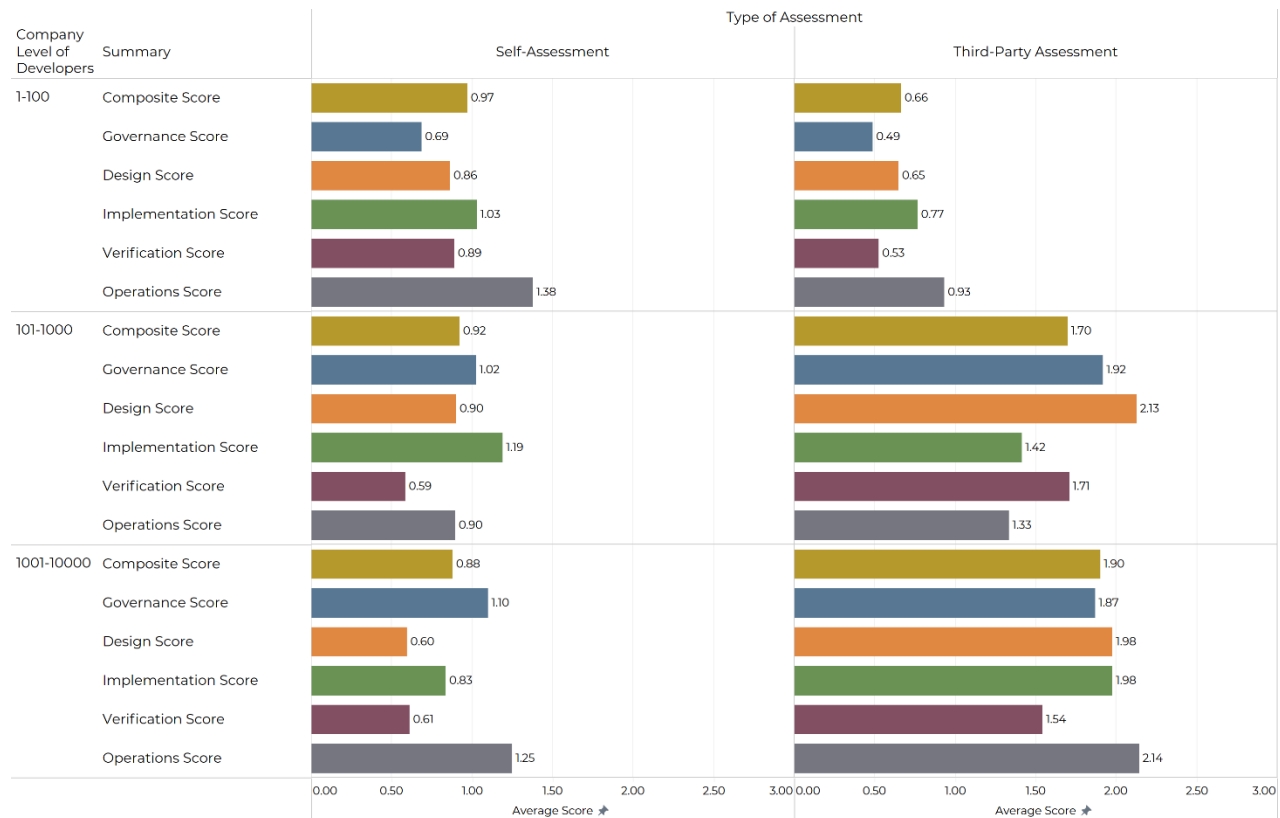


Figure 3: Self vs. 3rd Party Assessments

There are two primary theories as to why we see this behavior. The first is that self-assessing companies try to improve their scores before hiring a third party to conduct an assessment. I've seen this behavior numerous times. The second is that it's common for self-assessors not to fully understand the terminology or intent behind the model's questions, and not to give themselves credit for the work they are accomplishing; they just don't realize it should be credited.

Assessment Scopes

SAMM assessments can be conducted on different scopes.

We normalized the demographic options on a full company, an organization (or business unit) within the company, and a team within an organization. In the contributed data sets, 28% of the assessments are at the company scope, 23% at the organization scope, and 49% at the team scope. As with industry verticals and geographic demographics, we believe this will be a valuable filter in the future, as a larger collection of assessment data will yield statistically significant results when filtered to match a desired profile.

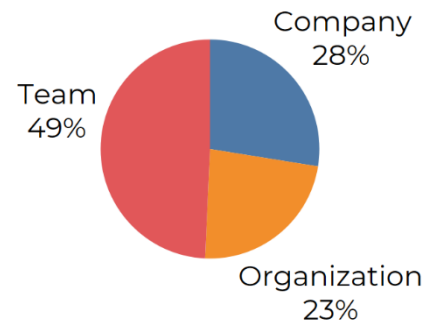


Figure 4: Assessment Scope

Number of Application Security People

One of the demographic questions the SAMM Benchmark collects asks how many people are in roles that are focused on Application Security. The data collection shows an alignment with organization size, where large and small numbers of Application Security personnel are more prevalent than in medium-sized companies with 6-20 Application Security personnel. We hope to collect data on more medium-sized companies in the coming months to better balance the overall dataset for analysis. We believe that the higher percentage of assessments identifying 20+ Application Security personnel is due in part to security champion programs, which result in a larger number being reported for this demographic measurement.

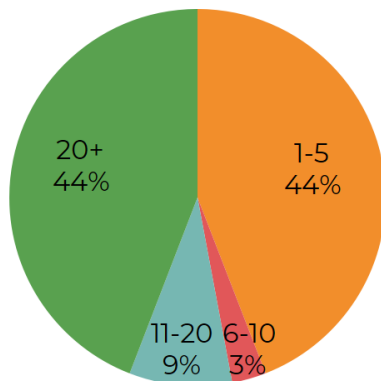


Figure 5: Number of Application Security People

OVERVIEW

Historically, based on over a decade of conducting SAMM assessments, I’ve stated that the average Composite Score is between 0.8 and 1.2 for most assessments. In the current data collection, the average Composite Score is 1.26, which is on the high end of the range. Also recall that nearly half of the assessments in the data collection are from large companies.

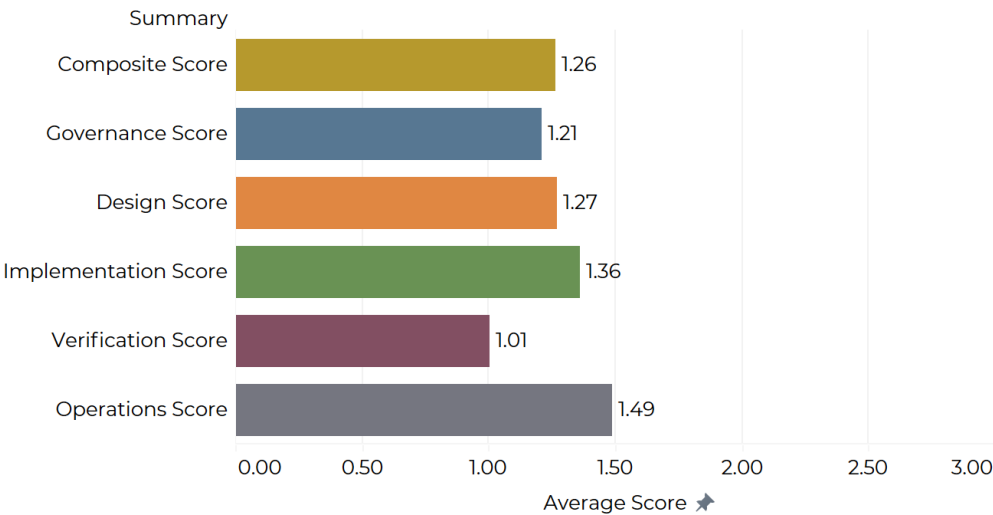


Figure 6: Average Scores for Business Functions

If you filter out the large assessments and look at the averages for the small and medium assessments, the average Composite Score is 0.79, which aligns with my experience over the last decade. The averages are approximately half a point lower when the large companies are removed from the average.

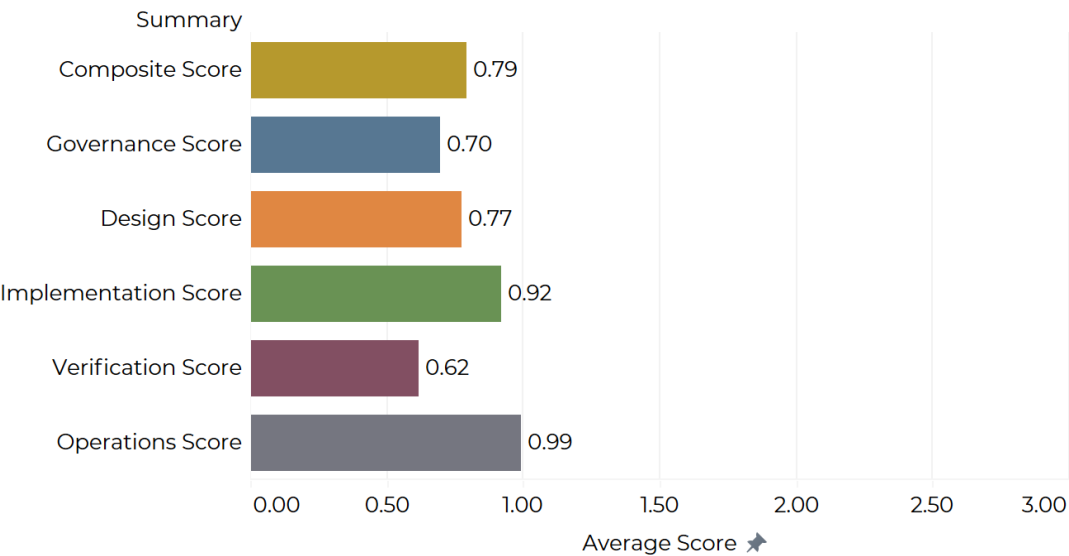


Figure 7: Average Scores for Small and Medium Companies

The Governance and Operations Business Functions are largely inherited or driven from outside the software development areas. Governance is usually managed at the company or enterprise level, with upper management, Compliance, and Legal driving many of the initiatives and security-related activities. Operations is similar on the other end of the model. The software teams will typically inherit the processes and controls from the well-established system operations and infrastructure teams. Cloud environments will also contribute to higher scores in Environment Management and Operational Management due to the highly structured environments offered by IaaS, PaaS, and SaaS.

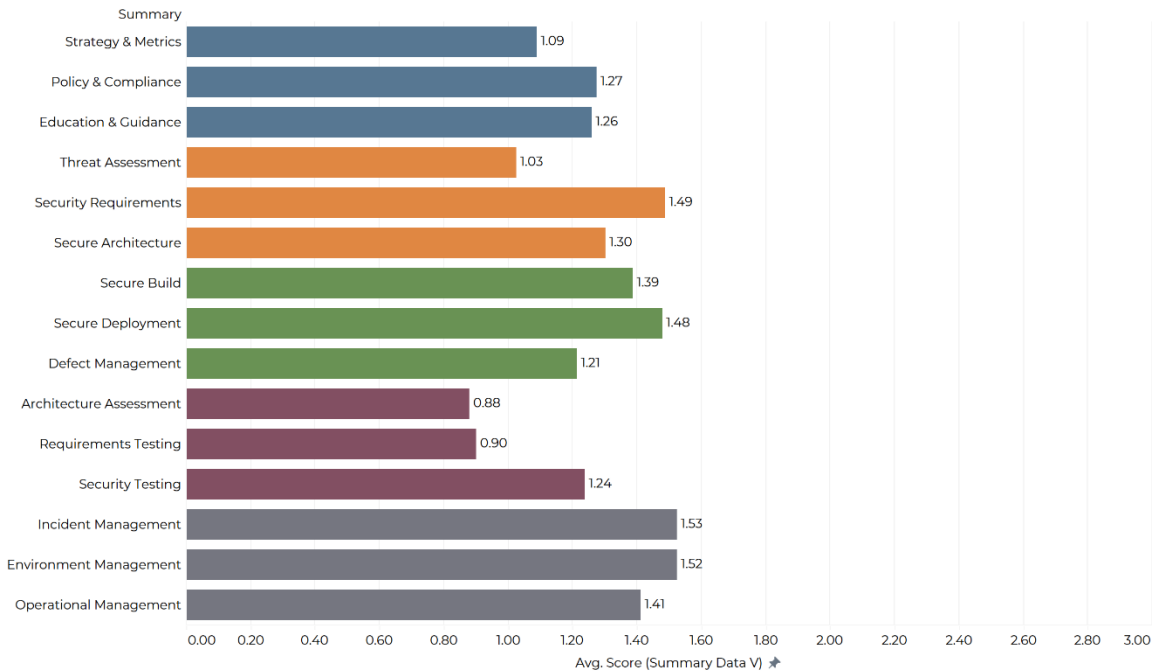


Figure 8: Average Score for Security Practices

Implementation scores are likely higher due to the continued adoption of CI/CD pipelines, DevOps, and DevSecOps. Repeatable deployment processes, formally described build processes, fully automated build processes, and protecting application secrets are among the Top 10 highest-scoring questions and are all in the Implementation Business Function.

OUR SUCCESSES

Operations has the highest overall score of the five business functions. With 3 of the top 5 security activities in Incident Response, Patching and Updating, and System Decommissioning / Legacy Management. Implementation is not far behind with 4 of the top 10 Security Activities in Build Process, Defect Tracking, Secret Management, and Deployment Process. Design provides Supplier Security and Technology Management in the top 10 Security Activities, while Governance contributes Training and Awareness to round out the top 10. The Verification Business Function is absent from the top list of Security Activities and, not surprisingly, has the lowest average score among Business Functions.

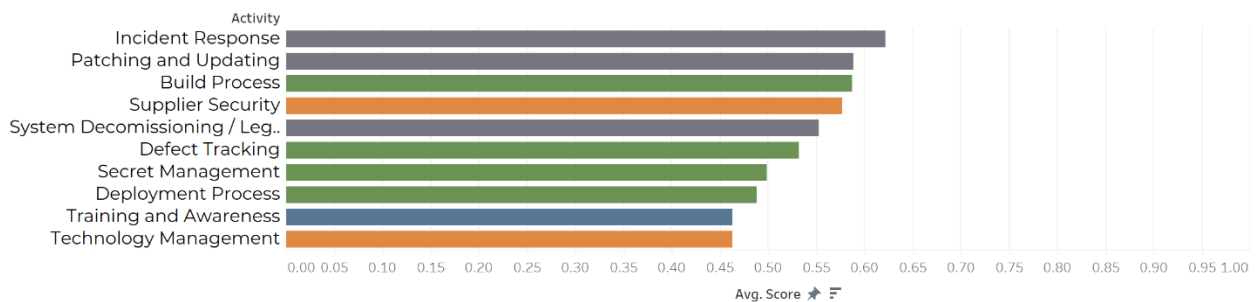


Figure 9: Top 10 High-Scoring Activities

If we look at the Top 10 High-Scoring Questions, the Implementation Business Function contributes half of the top 10, with repeatable deployment processes, formally described builds, tracking of security defects, fully automated build processes, and limiting application secrets to least privilege. Operations is following right behind with four questions, including responding to detected incidents, properly protecting and handling information, patching vulnerable components, and removing end-of-life systems. Governance rounds out the top 10 with understanding external compliance and a common set of policies and standards. Yes, that adds up to 11; there is a tie in the 10th position. Another interesting item of note is that all but one of these questions are from Maturity Level 1, which is not surprising, as they should be the first to be completed. There is one Maturity Level 2 question in the top 10, and it's related to having a fully automated build process.

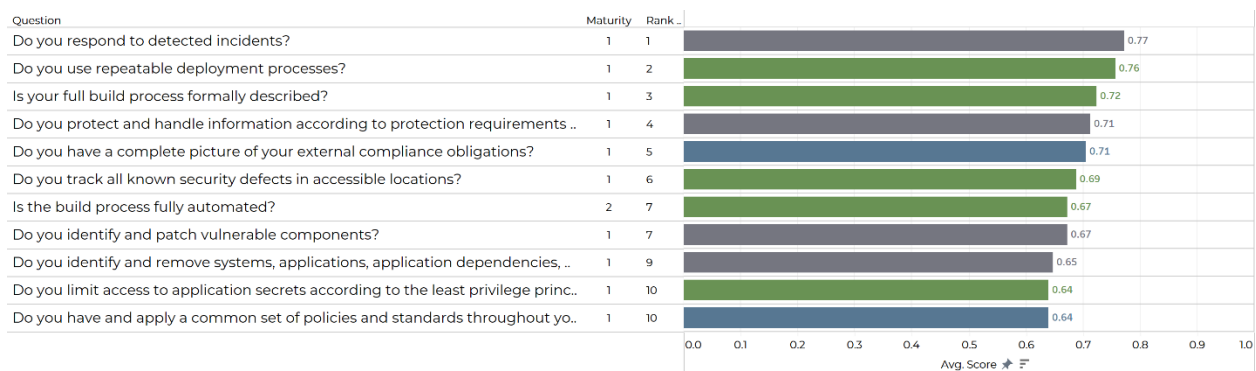


Figure 10: Top 10 High-Scoring Questions

OUR CHALLENGES

Conversely, in the Bottom 10 Low-Scoring Activities, we find all the Business Functions represented, with Verification leading the way with 4 of the 10 activities, including Misuse/Abuse Testing, Architecture Mitigation, Architecture Validation, and Control Verification. A common theme will emerge when we look more closely at Design: there is still much work to do in architecture and threat modeling. Misuse/Abuse Testing includes randomization and fuzzing, abuse cases, and denial-of-service and security stress testing; all of which receive very low scores. Control Verification has reasonable scores at Maturity Level 1 for basic security testing, but automating security testing and following up with regression testing are areas companies are struggling to implement.

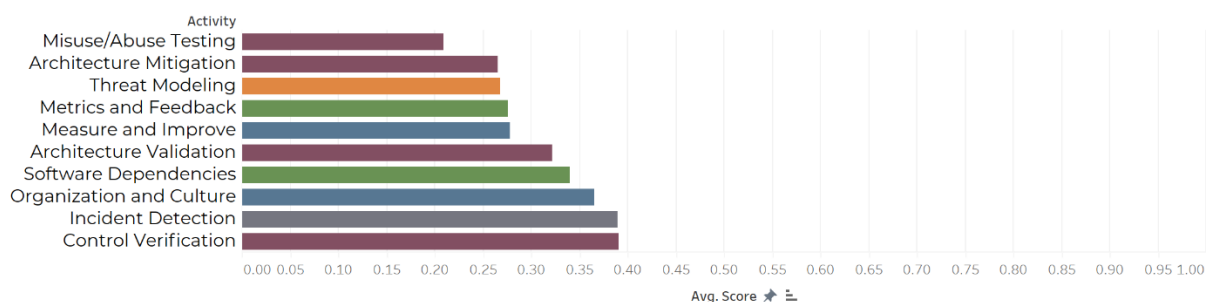


Figure 11: Bottom 10 Low-Scoring Activities

Implementation contributes Metrics and Feedback, as well as Software Dependencies, to the Bottom 10 Security Activities. Creating and maintaining effective metrics that drive desired, beneficial changes is challenging for most people. Managing Software Dependencies (aka the Software Supply Chain) is also identified as a major challenge. Design ranks Threat Modeling as the third-worst-scoring activity. Given the recent industry focus on threat modeling, including its inclusion in the OWASP Top 10 2021 at #4 and #6 in the OWASP Top 10 2025, we hope to see this score increase.

Governance has two entries in the Bottom 10 Low-Scoring Activities: Measure and Improve and Organization and Culture. There are two primary places in SAMM where metrics are measured, and both are in the Bottom 10 Security Activities. Organization and Culture focuses on Security Champions and on building and maintaining knowledge transfer mechanisms to improve the effectiveness of an application security program.

If we look at the Bottom 10 Low-Scoring Questions, by far the lowest-scoring question asks whether you are willing to prevent the build of software if vulnerabilities are identified in the dependencies. This is not surprising, as it's likely a combination of many companies not having matured their software supply chain processes to the point of using only known-good dependencies, and the potential negative impact on the schedule caused by blocking builds. Given the high rate of vulnerabilities in dependencies, if they aren't well managed, enabling this feature could significantly delay the development and release schedule. Verification also has the third lowest scoring question in evaluating the effectiveness of security metrics, and Governance adds defining KPIs to the bottom 10. The companies I've worked with in the past typically have metrics from various tools but struggle to build metrics and dashboards that they feel accurately assess risk and drive the desired behavior.

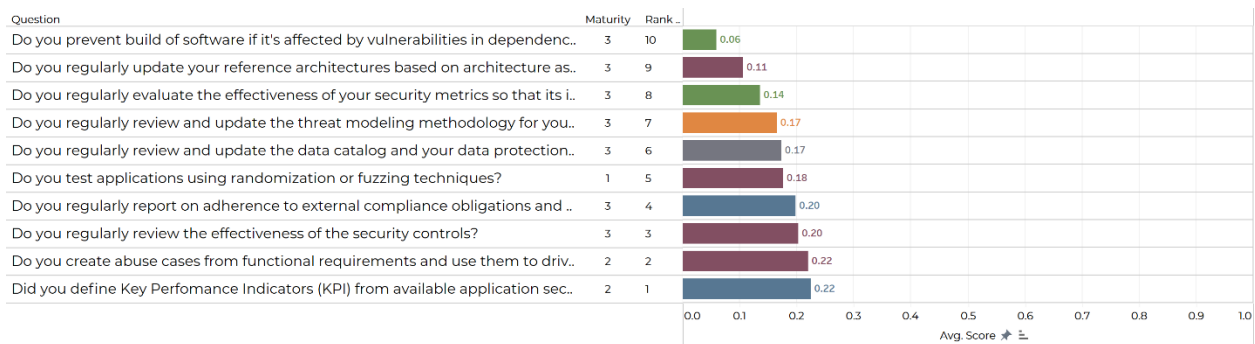


Figure 12: Bottom 10 Low-Scoring Questions

Other low-scoring questions include updating reference architectures, updating threat modeling, updating a data catalog, and other more mature continuous improvement types of work. These are higher maturity level questions, and if the team/organization/company hasn't done the initial work, or just completed it, it stands to reason they haven't reached the point where they can update or improve it.

Another interesting insight is that Verification has 4 of the bottom 10 questions. This includes updating reference architectures, randomization or fuzzing, reviewing the effectiveness of security controls, and creating abuse cases. In some ways this is surprising, as traditionally we thought that Verification would score higher because companies have been trying to “test themselves secure” for years as a primary security strategy (which doesn't work if you hadn't noticed). It may be that, if we look more deeply into the security testing, we find many tools thrown at the problem that make a lot of noise and cost money but don't actually provide the risk management we thought they would.

INSIGHTS AND PATTERNS

In this section, we'll look at different insights and patterns that we can uncover in the data.

Maturity Level Analysis

Reviewing the questions at Maturity Level 1, as they are the first level of maturity, they should score higher out of the 90 questions within SAMM. Starting from the bottom of the rankings, the question about using randomization or fuzzing techniques is ranked #30 of 30 in Maturity Level 1 questions and #85 of 90 across all questions in SAMM. To round out the bottom half of all questions, threat modeling is #46 of 90, analysis of log data for security incidents is #56 of 90, and using metrics to improve security is #66 of 90. These are the primary areas that companies are struggling with that should be starting points. There is one Maturity Level 1 question in each of the five Business Functions that companies struggle with, and these questions are among the bottom 6 for this maturity level.

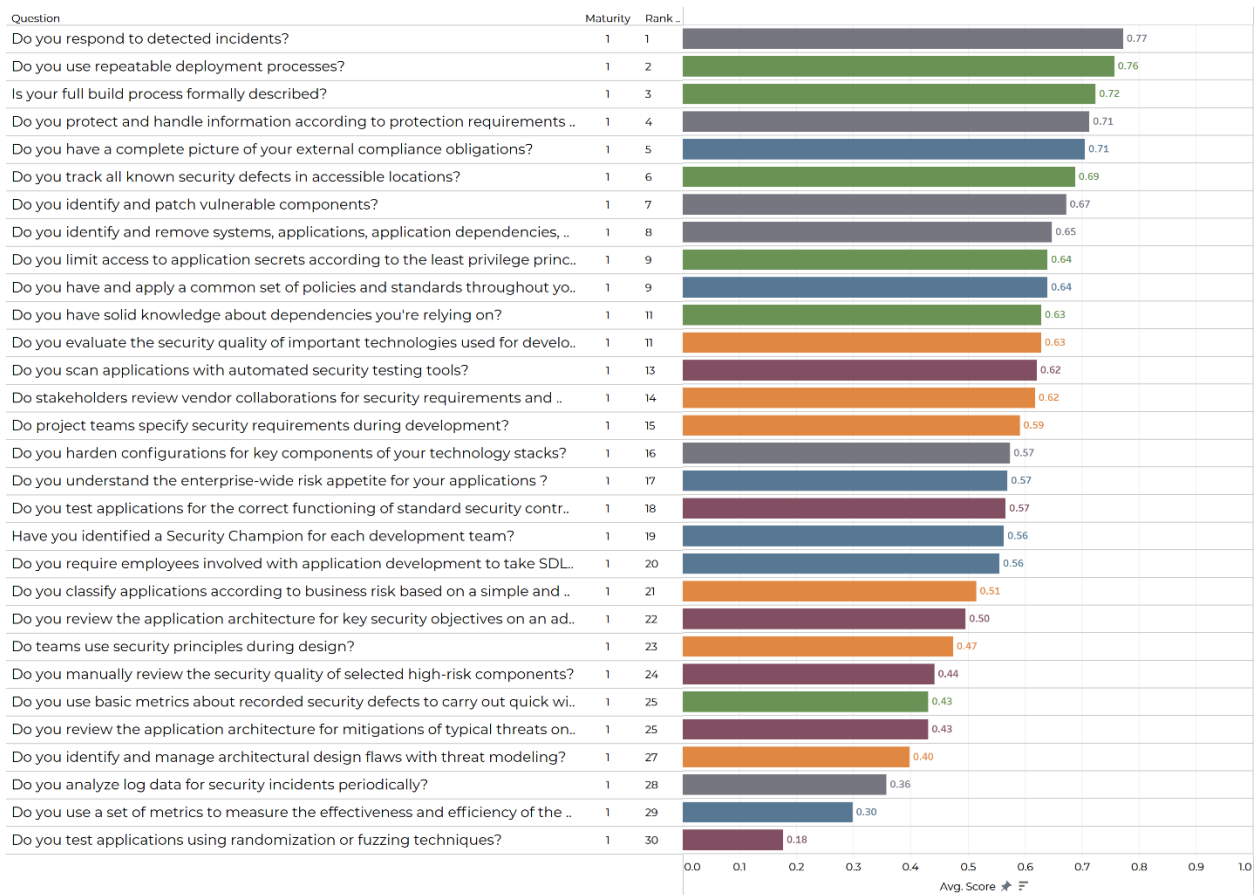


Figure 13: Maturity Level 1 Questions

Analyzing the Maturity Level 2 scoring, the areas that most companies struggle with are creating abuse cases from functional requirements (#82 of 90), defining KPIs (#81 of 90), standard threat modeling methodology (#76 of 90), improving your program based on metrics (#73 of 90), a cluster of three Validation questions in the low 70s of 90). Maturity Level 2 is rough in the Governance Business Function: the best-scoring question in a standard set of security requirements is ranked #12 of 30 in Maturity Level 2 but #43 of 90 overall. Verification is worse: penetration testing ranked #33 of 90 as the best showing, and the next higher Maturity Level 2 question for Verification is consistently "write and execute test scripts," which ranked #52 of 90.

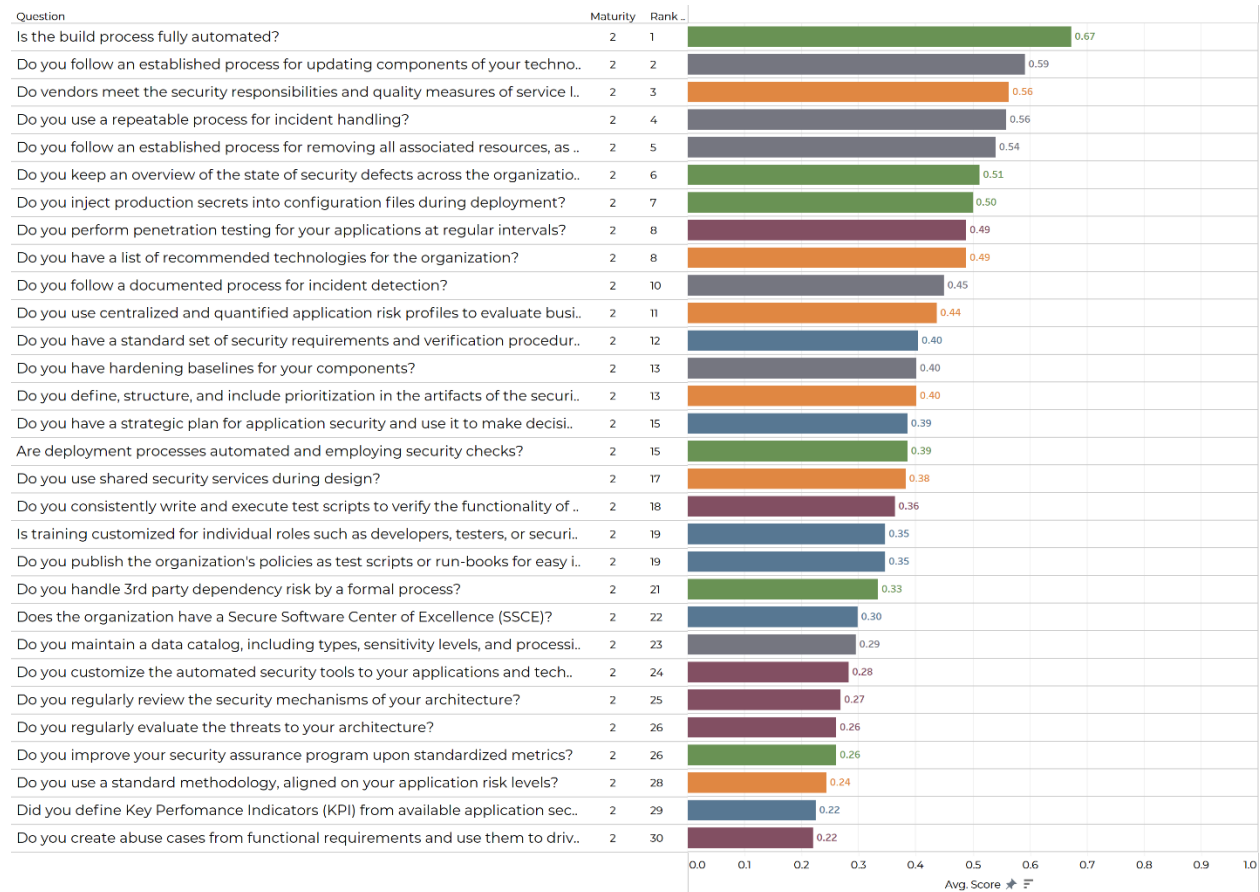


Figure 14: Maturity Level 2 Questions

Maturity Level 3 is the hardest level to achieve, as there is a lot of work to be done and culture to be put in place before many questions can be answered for a higher score. Operations and Implementation generally score higher than the other Business Functions for Maturity Level 3. However, the average for Implementation is dragged down by responses to blocking the build if there are vulnerabilities in dependencies and by evaluations of the effectiveness of security metrics, as these questions rank among the bottom three. If we remove the large companies, these two questions will switch places but will still be in the bottom three.

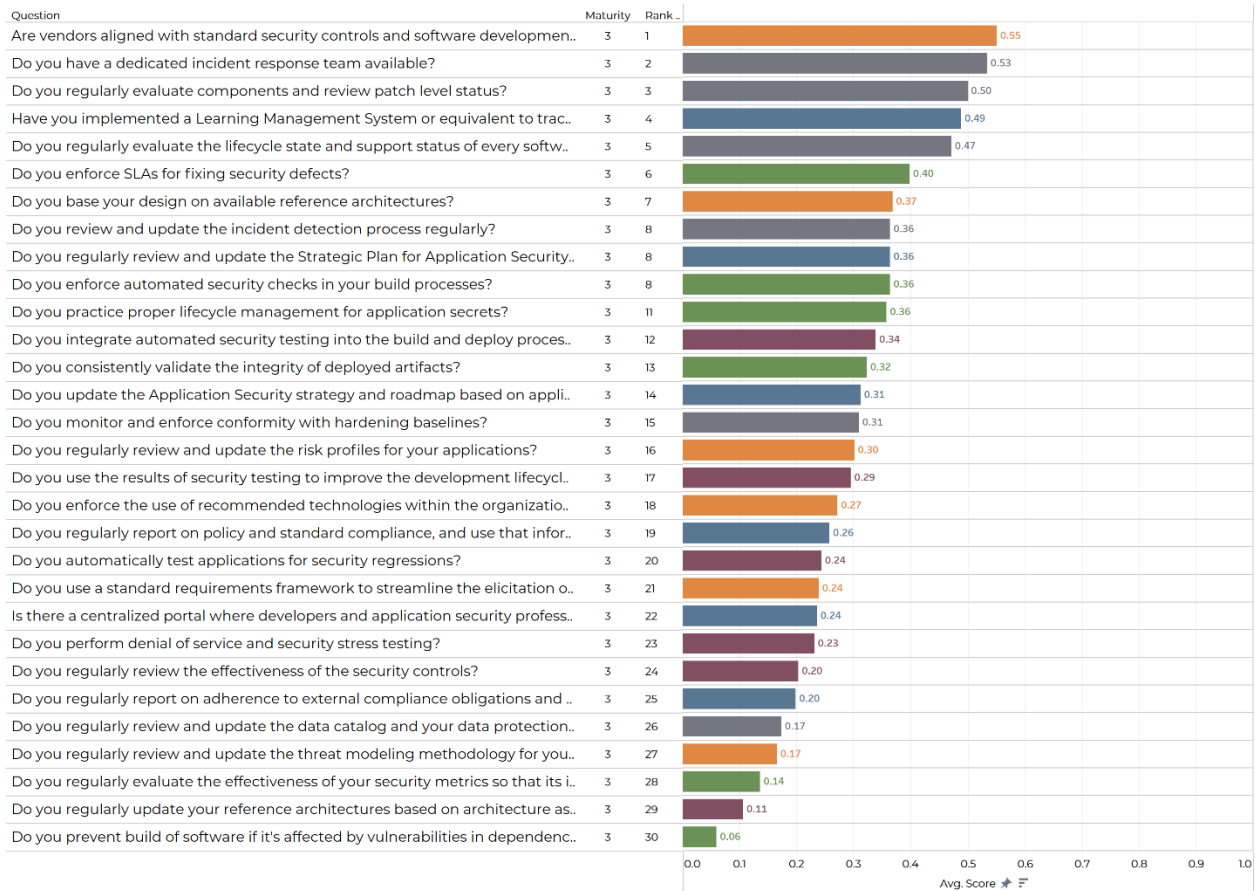


Figure 15: Maturity Level 3 Questions

At the high end of Maturity Level 3 questions, vendor alignment with secure software development ranks #25 out of 90 and is higher than many Maturity Level 1 and 2 questions. One interesting trend is that companies indicate they use reference architectures as baselines and starting points for future work (ranked #7 of 30), but they implement a standard security requirements framework much less frequently (ranked #21 of 30). This may be attributed to attempts to build security requirements into the reference architectures, rather than to a formal framework for security requirements with defined baselines that can be mapped across policy, standards, test cases, and validation.

Related Security Activities

In this section, we'll look at where companies are focused and interesting relationships between different areas in the model.

SMALL COMPANY FOCUS AREAS

If we focus on small companies and look at the top 10 questions they answer with the smallest percentage of “No (0.0)”, we get the following list that includes a three-way tie for 10th, so technically the top 12 questions.

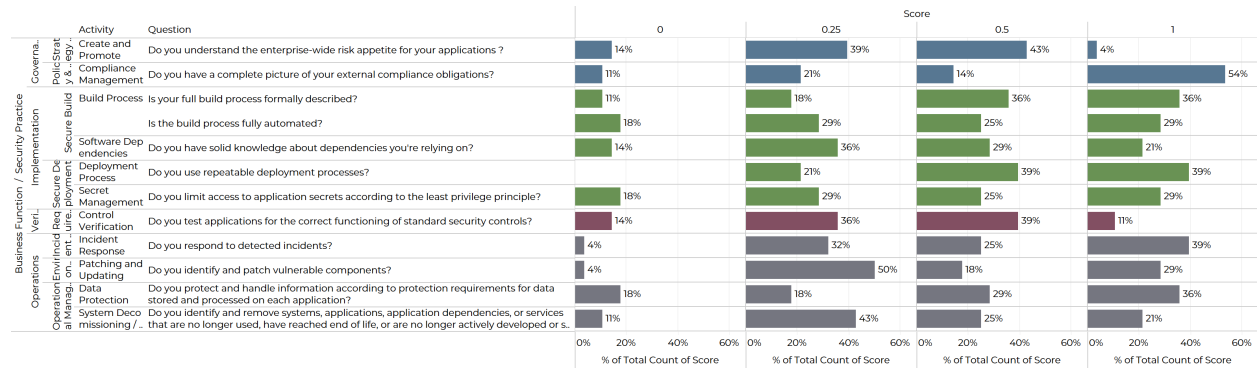


Figure 16: Top 10 (12) Scoring Questions for Small Companies

Small companies have most of their efforts focused on Implementation and Operations. In Governance, the understanding of their risk appetite is often limited, typically held as tribal knowledge due to the smaller number of applications they manage. Understanding external compliance obligations typically stems from external pressures and can carry heavy penalties, hence the higher level of effort in that space. There are no questions from the Design Business Function at this level; we would need to expand to the Top 20 before we start seeing Security Activities such as Technology Management, Application Risk Profile, and Software Requirements. For the Implementation Business Function, companies focus their efforts on build and deployment processes, understanding their dependencies, and limiting access to secrets.

Verification only has basic security testing in this list; we would need to expand to the Top 20 again before we start seeing automated security scanning, manual review of high-risk components, and penetration testing. Operations focuses on incident response, patching vulnerable components, basics about information handling, and maintaining systems (which has largely been handled by cloud providers).

I considered looking at the areas where small companies struggled most, but that list is pretty long, and I don't believe it would yield valuable insights. There aren't enough entries in the data collection to focus on medium-sized companies, so we'll move on to examining challenges facing large companies.

LARGE COMPANY CHALLENGING AREAS

If we filter the questions to the top 10 with the highest percentage of “No (0.0)” answers, we can examine some of the challenges facing large companies.

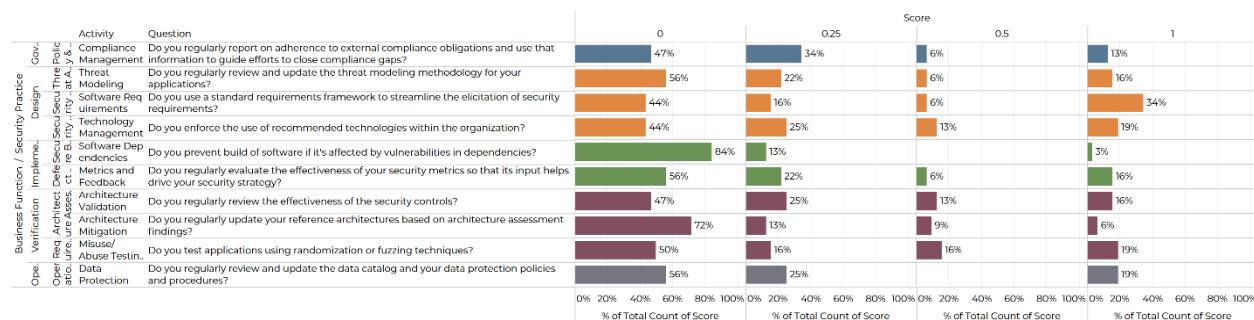


Figure 17: Top 10 Questions Challenging Large Companies

In Governance, reporting on external compliance obligations has one of the lowest scores for large companies. This could be due to the activity not being done, or to the people interviewed in the assessments not knowing it's being done. For Design, the questions include updating the threat modeling process, using a standard requirements framework (such as OWASP ASVS, NIST SP 800-53, or similar), and enforcing the use of recommended technologies. Lack of updates to the threat modeling process is not very surprising, as standardized threat modeling processes are still not widespread. The limited use of a requirements framework is a little surprising to me; that's a fairly mature and well-known space (at least for Cybersecurity). The struggle with enforcing the use of only recommended technologies is usually due to resource limitations or constraints in building and maintaining repositories of known-good software and libraries.

Implementation challenges focus on preventing the build if vulnerabilities are found in dependencies and on evaluating the effectiveness of security metrics. Preventing the build is the lowest-scoring question in the model; most of the time, the feedback has been that vulnerability scanning introduces too much noise and that CVEs aren't applicable enough to justify the disruption of blocking a build. Metrics is a common theme across Governance and Implementation, posing a challenge for companies of all sizes. Verification challenges stem from architecture review activities, such as assessing the effectiveness of security controls and updating reference architectures based on findings, and the lack of randomized and fuzzing-style testing. Operations contributes the challenge of reviewing and updating the data catalog and related policies and procedures.

GOVERNANCE

Governance is an interesting Business Function within SAMM. This function is not typically included in Secure Development Lifecycles, but it is critical for providing a foundation for the rest of the security activities. On the top end, external compliance, policies and standards, security champions, and secure development training are doing fairly well. On the other hand, metrics, KPIs, knowledge sharing, and reporting score quite low, and this includes the large companies in the averages.

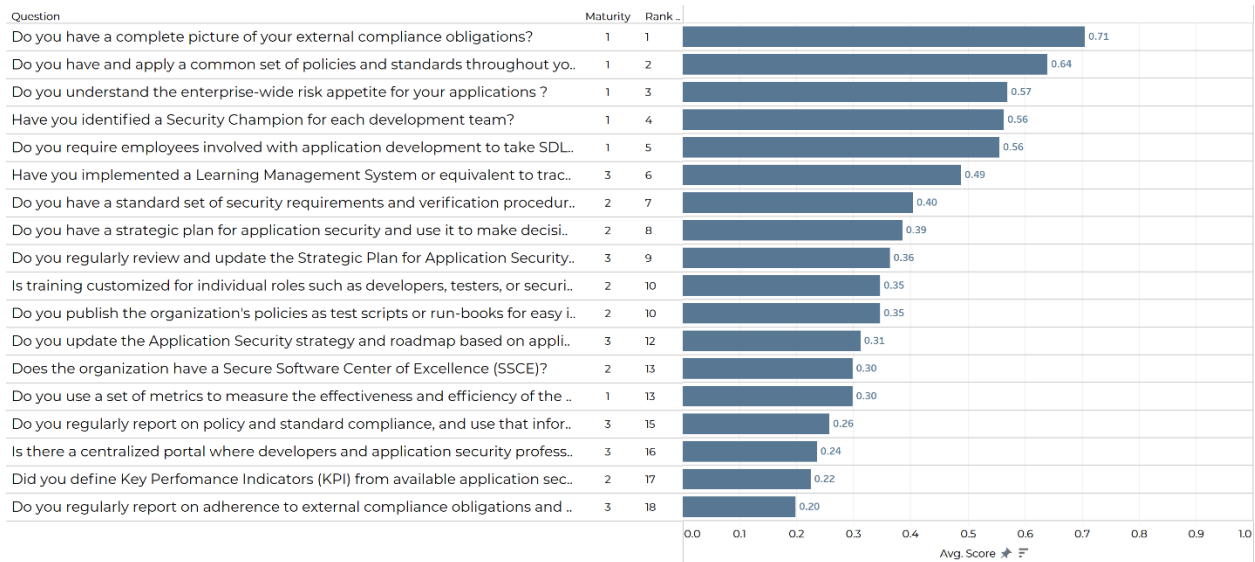


Figure 18: Governance Questions

If we take a close look at the breakdown of how the questions are answered, we can see a significant difference between large and small companies in Governance functions. This is driven by a couple of factors. The first is that larger companies face greater external pressure to implement more governance activities. Clients and customers, government regulations, industry compliance, and other forces will mandate higher levels of maturity through governance capabilities. The second is that smaller companies may not face similar external pressures, and they simply don't have the headcount to manage the overhead required to build and maintain a mature governance program. You can see these differences in the distribution of scores for the Governance Business Function. When large companies are included in the averages, many more questions are answered with "most or many," which score 1.0 points. The other interesting thing to note is that, in Governance, the answers are typically "No (0.0)", "Some (0.25)", or "Many or Most (1.0)", with "At least half (0.5)" only a small percentage of the time. This is indicative of either they haven't started the activity, they just started it, or they are mature in that area.

Software Assurance Maturity Model Benchmark Report – June 2026

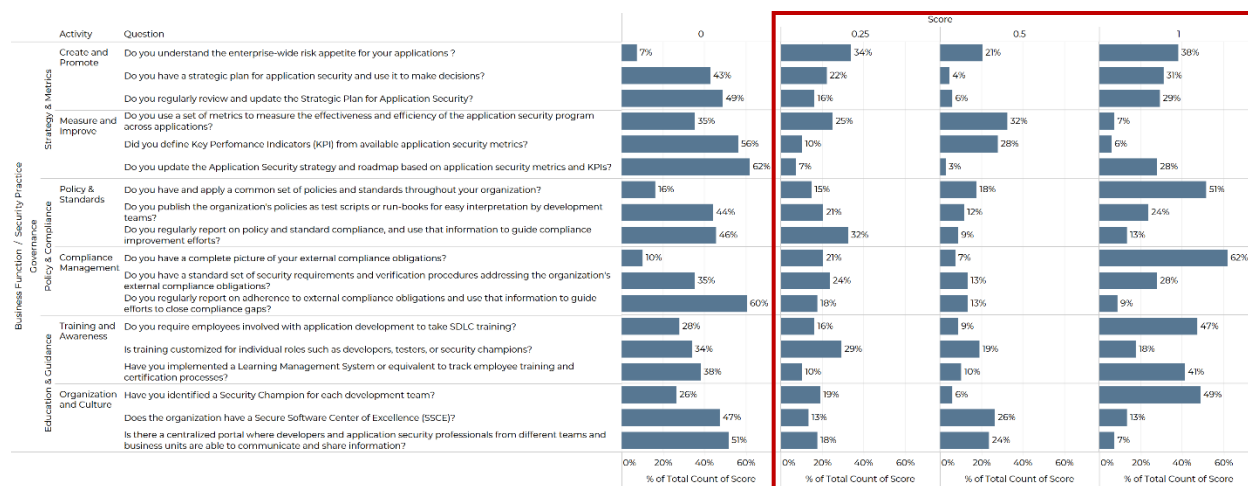


Figure 19: Breakdown of Governance Questions

If you look at the distribution of the “Some (0.25)”, “At least half (0.50)”, and “Many or Most (1.0)” in Figure 15 that includes all assessments in the data collection, then compare to Figure 16 with the large companies removed, you will notice a major drop-off in the answers. The larger companies are clearly showing more mature, broad governance programs, while small to medium companies do not have governance in place where they have the latitude to do so. The one exception here is understanding external compliance obligations; this distribution is still almost the same, most likely due to legal requirements.

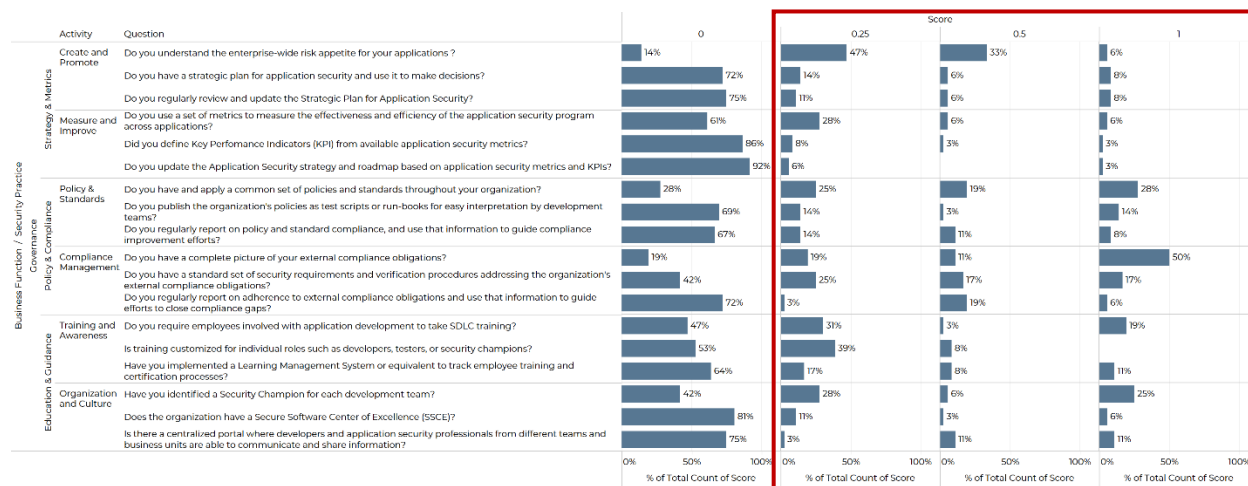


Figure 20: Governance Questions for Small and Medium Companies

Small and medium companies are trying to build a complete application inventory but are struggling to achieve full coverage, as evidenced by the distribution of answers to the first question about the risk appetite for applications. Common policies and standards are another strong area for small and medium companies, which is a good sign, as they serve as a foundation for many other security activities. There is evidence for the growth of security champion programs in the assessment data, which is also an excellent trend that will hopefully continue to improve.

DESIGN

Design is an important Business Function where we focus on application risk profiles, threat modeling, secure design principles, security requirements, technology management, and supplier security. Evaluating the security quality of technologies used in development is the highest-scoring question in Design; even when we look only at small and medium companies, it remains the highest, with a score of 0.46. Vendor management is highly ranked; even the Maturity Level 3 question on alignment with internal security controls, development tools, and processes scores above the Maturity Level 1 questions related to risk classification for applications (inventory and ranking) and to using security principles in architecture and design. While this is great for vendor management, it's very concerning for some of the basics of building and maintaining an application inventory with risk ranking, and leveraging the fundamental principles for secure architecture.

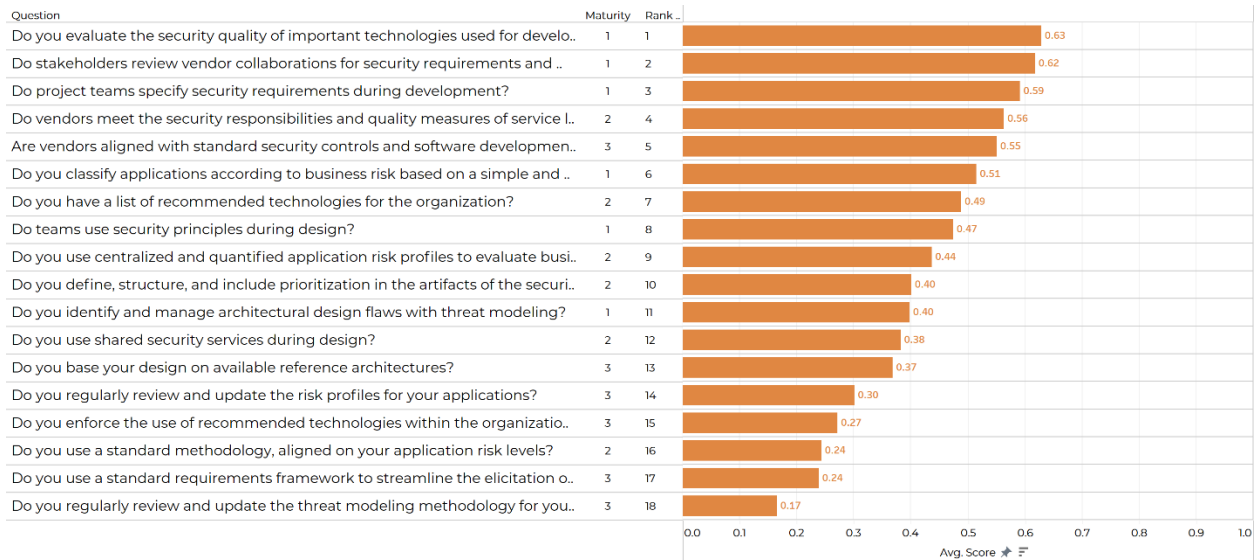


Figure 21: Design Questions

Of the three Security Practices in the Design Business Function. Threat Assessment is by far the lowest-scoring practice. The questions of “do you threat model? (1)”, “do you use a standard methodology? (2)”, and “do you update the threat modeling? (3)”, ranking at 11th, 16th, and 18th (last), respectively. Threat modeling has been shown to be a consistent challenge to implement, and the current deluge of AI into the development process threatens to halt or reverse the slow improvement of the last 3-4 years by claiming that design and architecture are too slow.

Also, while companies specify security requirements (ranked #3), a more formal requirements process is ranked #10 in Design, and using a standard requirements framework such as OWASP ASVS, NIST 800-53, or related frameworks is ranked #17 (second-to-last). This can be interpreted as a dependency on the tribal knowledge of senior architects or leads to define or oversee security requirements, which is something I’ve observed in many SAMM assessments.

Software Assurance Maturity Model Benchmark Report – June 2026



Figure 22: Breakdown of Design Questions

If you compare the differences between the distribution of answers for questions in the Design Business Function, the primary high-level difference is that large companies answer "many or most (1.0)" a lot more often. There is not a huge difference in the midrange for scoring (0.25 and 0.50). In smaller companies, the Application Risk Profile and Threat Modeling scores are much lower than in large companies. This may be due to a mix of a small enough portfolio of applications that people use tribal knowledge to manage the risk, and the amount of overhead to build and maintain an application inventory that is risk-ranked is cost-prohibitive for small companies.

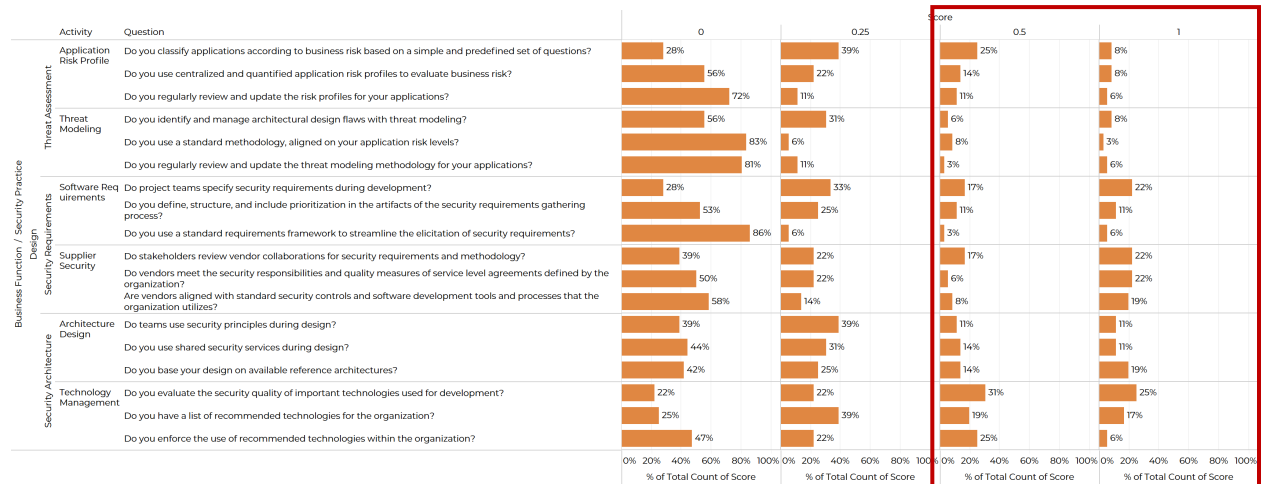


Figure 23: Design Questions for only Small and Medium Companies

Interesting challenges that both large and small companies seem to share are in the Architecture Design practice with secure design principles and reference architectures, enforcing the use of recommended technologies, and updating threat modeling processes. Notably, 86% of small and medium assessments say they do not use a standard requirements framework for security requirements, but this rises to 66% across all assessments (including large companies).

IMPLEMENTATION

Implementation is the second highest scoring Business Function among the five and has five of the top 10 highest-scoring questions. With the last several years focused on building and deploying software, mostly through CI/CD pipelines, we are seeing the results of those efforts reflected in these assessment scores. Repeatable deployment processes, fully described builds, automation in the build process, and integrated secret management all score near the top in the Implementation Business Function.

However, enforcement of automated security tools in the build process is ranked #12 out of 18, and validating the integrity of deployed artifacts is ranked #15 out of 18, so there is still important work to be done in this area.

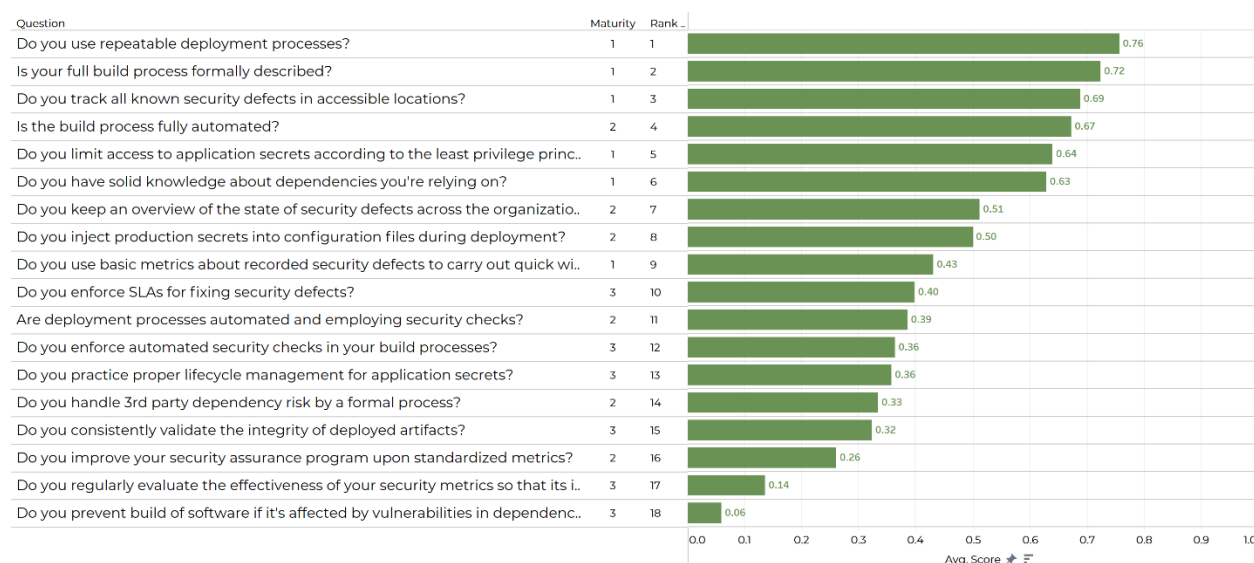


Figure 24: Implementation Questions

There is a similar story related to metrics at this deeper level in Implementation as we saw at the higher level in Governance. The three metrics questions of “do you use basic metrics? (1)”, “do you improve based on metrics? (2)”, and “do you evaluate your metrics? (3)”, rank at #9, #16, and #17 (second to last) respectively. I remember attending my first OWASP conference in Seattle, WA, in 2006 when we were building the AppSec program at FedEx, and the focus was on solving the security metrics problem. It’s been 20 years, and we are still struggling to define metrics that can be captured and provide valuable insights that encourage appropriate risk management actions.

One interesting challenge in Implementation is the lowest-ranked question in all of SAMM: whether you prevent the build of software when vulnerabilities are found in dependencies. This isn’t about company size; the score distribution essentially stays the same with and without factoring in the large companies. This is one of the rarest controls, and it could be argued that a company should implement it only if it needs a very high level of assurance in its software builds. It’s also likely that there is so much noise in the tooling for finding vulnerabilities that it’s not worth blocking the build on a high probability of a false positive or of it not being in the active or potential execution flow of the code.

Software Assurance Maturity Model Benchmark Report – June 2026

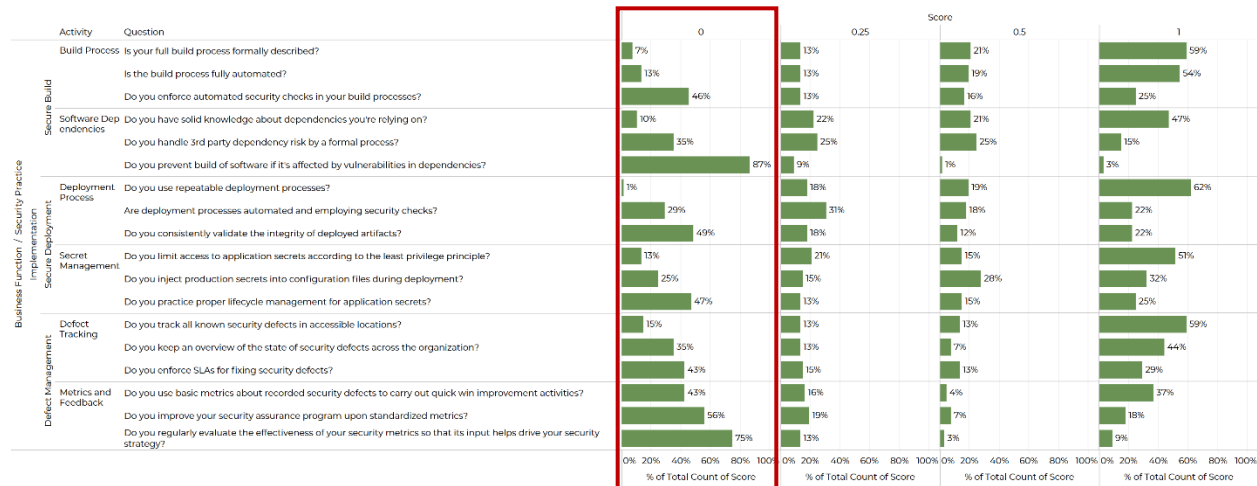


Figure 25: Breakdown of Implementation Questions

One of the more interesting differences between small and medium companies and large companies is that neither is doing particularly well at security metrics. Large companies are more likely to have the basics, but the percentage of “No (0)” answers is still really high for them. It’s reasonable to attribute the increase in basic metrics for large companies to security tooling and centralization, which are more common when budgets are large enough to implement them.

(Note: I thought about including the satirical cartoon about the Museum of Meaningless Metrics that has displays for Lines of Code, Story Points, Pull Requests, and their new exhibit for Tokens Spent, but it’s AI-generated and I don’t have a good way to provide attribution to an authorless work.)

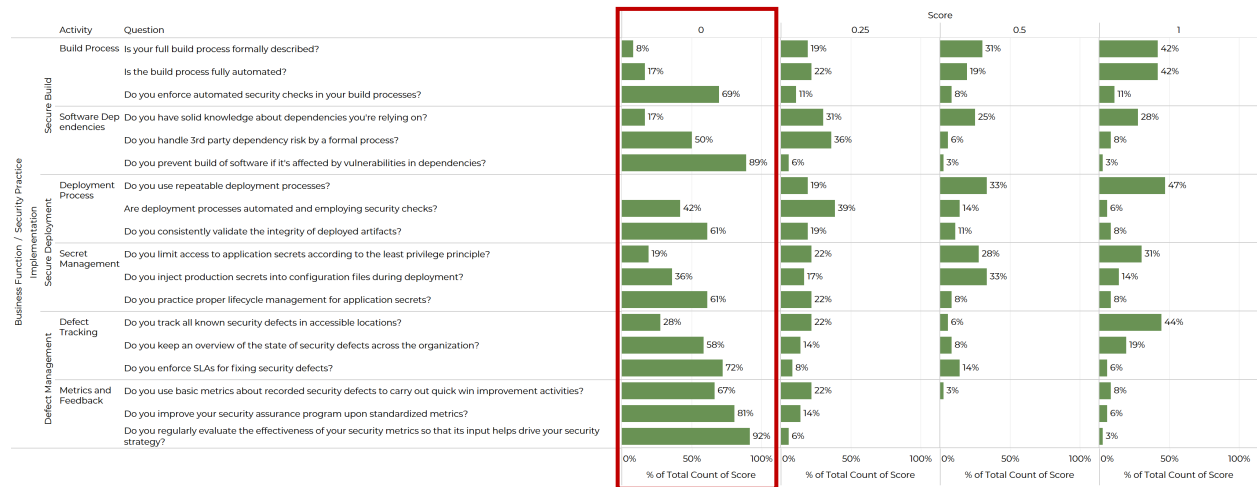


Figure 26: Implementation Questions for only Small and Medium Companies

It’s been consistent in my assessment experience, and the data is aligned, that smaller companies aren’t at the point where they have enough resources (human and financial) to invest in implementing metrics programs. They are more focused on producing products and features that will enable them to generate enough revenue to grow or stay in business.

VERIFICATION

Given the history of organizations attempting to “test themselves secure”, it was expected that the Verification Business Function would score higher than it does. Automated testing tools are the highest-scoring question in this function, security testing and penetration testing following close behind. However, it’s interesting to note that writing and executing test scripts is ranked #7, integrating automated security testing into builds and deployments is ranked #8, and automated regression testing is ranked #13. This can be interpreted as many instances in which companies are dropping a security scanner into code repositories or using it for ad hoc testing, but not developing security testing automation specifically for the software they develop.

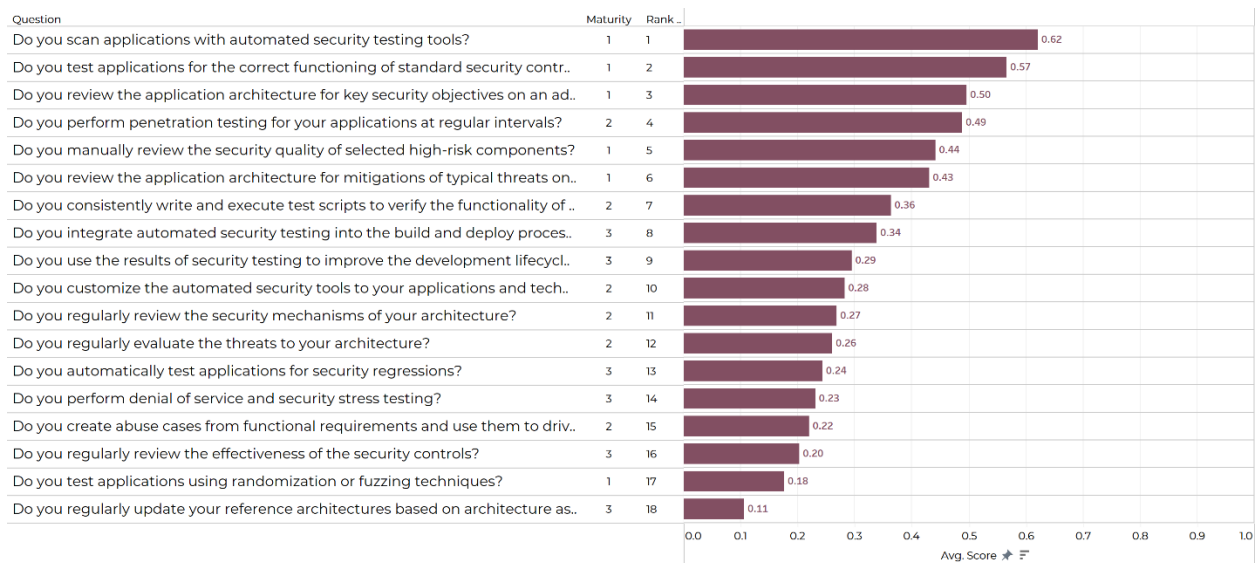


Figure 27: Verification Questions

At the lower end of the spectrum, Misuse/Abuse Testing is the lowest-scoring Security Activity in SAMM. Denial of service or stress testing is ranked #14, abuse cases from functional requirements is ranked #15, and randomization or fuzzing is ranked #17 out of 18 questions in the Verification Business Function. The other areas that struggle are reviewing the effectiveness of security controls and updating reference architectures. Few companies are at the point where they revisit whether the security controls they implemented are doing what they believe they are supposed to do. The implementation of reference architectures varies wildly, so it’s not too surprising that updating the reference architectures scores so low, as most companies are still struggling to implement them in the first place.

As a core team, we’ve discussed possibly switching the randomization and fuzzing with creating abuse cases from functional requirements. However, creating abuse cases barely scores any higher, so it’s still something we are evaluating for a change.

Software Assurance Maturity Model Benchmark Report – June 2026

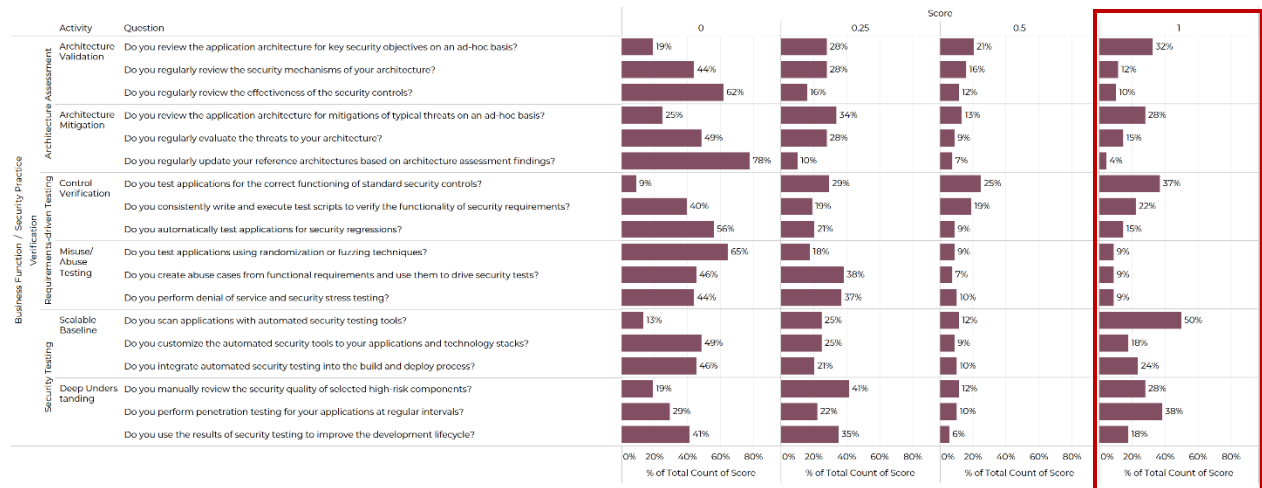


Figure 28: Breakdown of Verification Questions

Architecture Validation is one of the lower-scoring Security Activities, but was largely expected to be there as the Architecture Design and Threat Modeling Security Activities are also lower-scoring, and it's dependent on them being done so there is something to validate. In contrast, I expected Architecture Mitigation to score much higher than second-to-last (only Misuse/Abuse Testing scored lower), as it is more focused on areas like threat intelligence and on considering external threats to an architecture. With a large increase in focus on threat intelligence programs, working groups, and collaborations, I expected to see a higher score in this Security Activity.

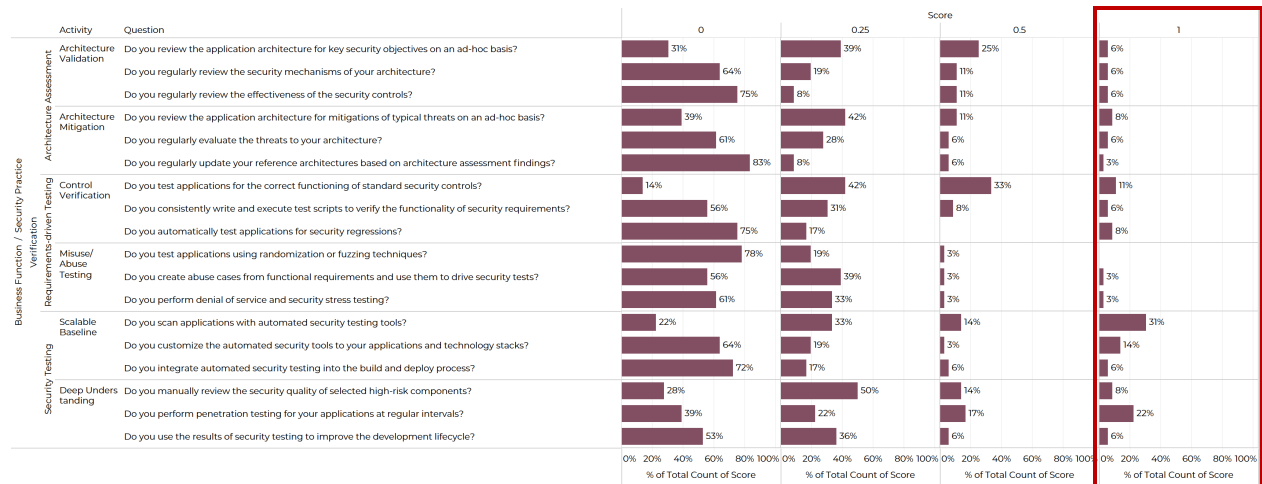


Figure 29: Verification Questions for Only Small and Medium Companies

For small and medium businesses, the only two areas with significant top scores are basic automated testing tools and penetration testing. Following behind is basic testing of properly functioning security controls. Almost everything else is scoring “No (0.0)” or “Few/Some (0.25)”, which is a little surprising considering the head start testing has had. One possible cause may be rooted in one of the oldest software development issues: when a schedule gets tight or is in danger of being overrun, testing is historically the area most pillaged.

OPERATIONS

As expected, Operations is the highest scoring Business Function, largely due to two factors. In general, Operations is the longest-running and should be the most mature area of SAMM, as the software will inherit the controls built for other systems, infrastructure, and related technologies. The second factor that impacts the Operations score is the standardization of cloud deployments and “as-a-Service” models, in which the provider manages the lifecycles, patching, and configurations for many resources across cloud offerings.

Software teams also tend to inherit mature incident response processes developed for the rest of the company. Interestingly, this isn’t as true for incident detection. Approximately a third of the contributed assessments answered “No (0.0)” to the three maturity questions about detecting incidents from application log data and having a related process to follow.

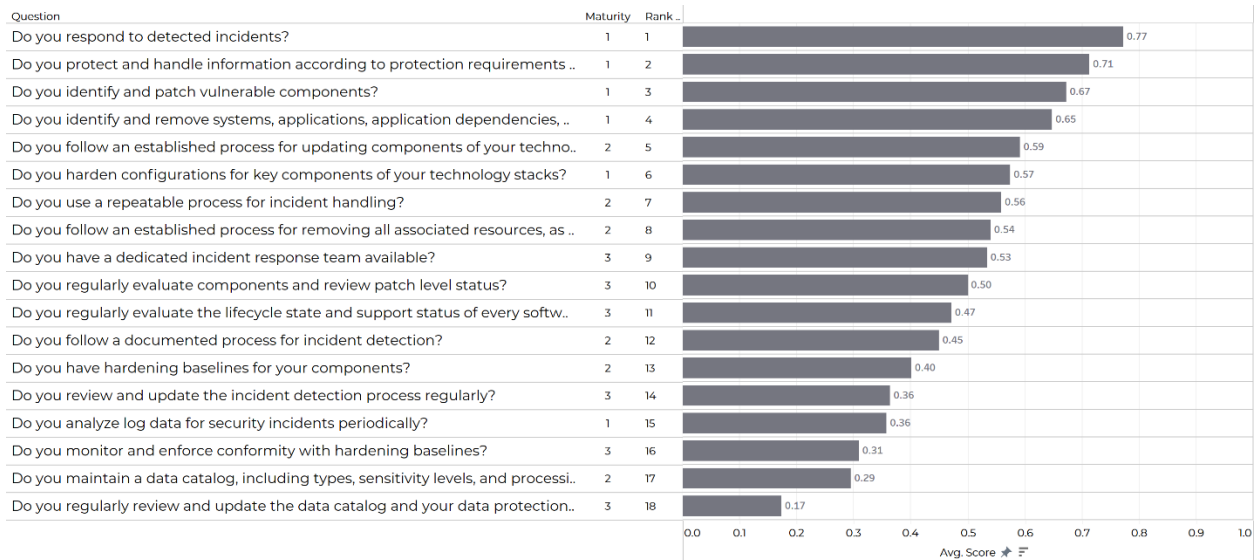


Figure 30: Operations Questions

Configuration Hardening provides some interesting insights: hardening configurations rank #6 of 18, while hardening baselines rank #13 and enforcing those baselines ranks #16. Several companies I’ve conducted assessments for have mentioned that they don’t really have chosen baselines or know what is in them. Rather, the “baseline” they are using is whatever the scanning tool they have implemented tests for in their configurations. As long as the tool provides an all-clear, they consider that good. This behavior results in a heavy reliance on the tool’s test suites to ensure they fully test known baselines for the environments they scan.

Companies that still manage their own data centers tend to score lower in Operational Management, particularly in System Decommissioning, because they can choose to postpone upgrades or retirements by accepting the risk or by implementing compensating controls. Cloud providers will typically just inform their customers that an EoL component will be replaced at a specific point in time.

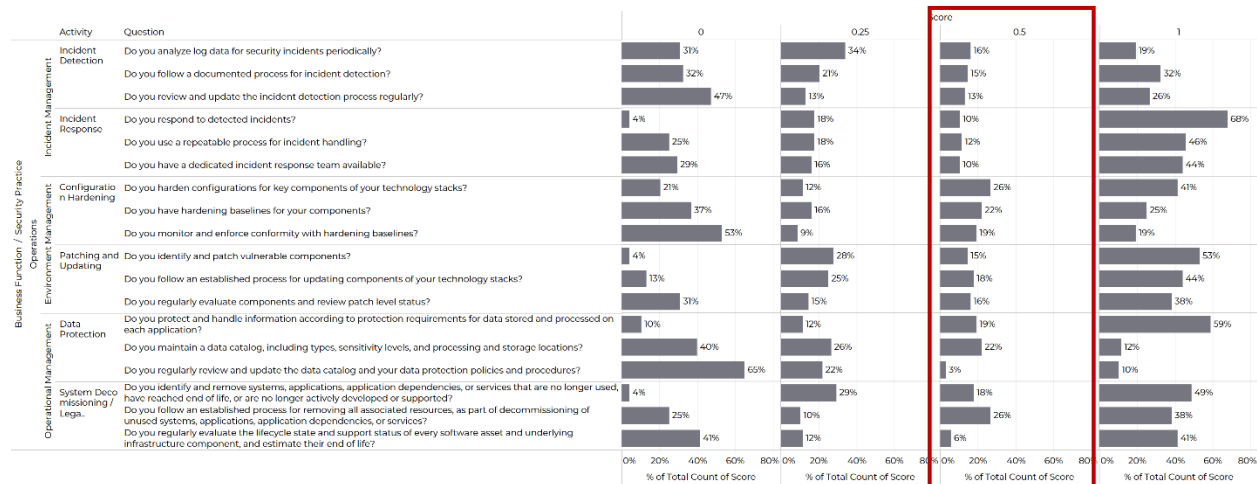


Figure 31: Breakdown of Operations Questions

The distribution of answers in Operations is interesting. The large companies definitely skew the averages upward; they provide many more “many or most (1.0)” answers. When they are removed from the averages, the small and medium companies are concentrated in the “Few/Some (0.25)” area, with more “No (0.0)” answers as well. The interesting part is that the percentages of “at least half (0.50)” don’t really change much at all. In this Business Function, either a company hasn’t started, just started, or has largely finished. There is very little in the middle ground here.

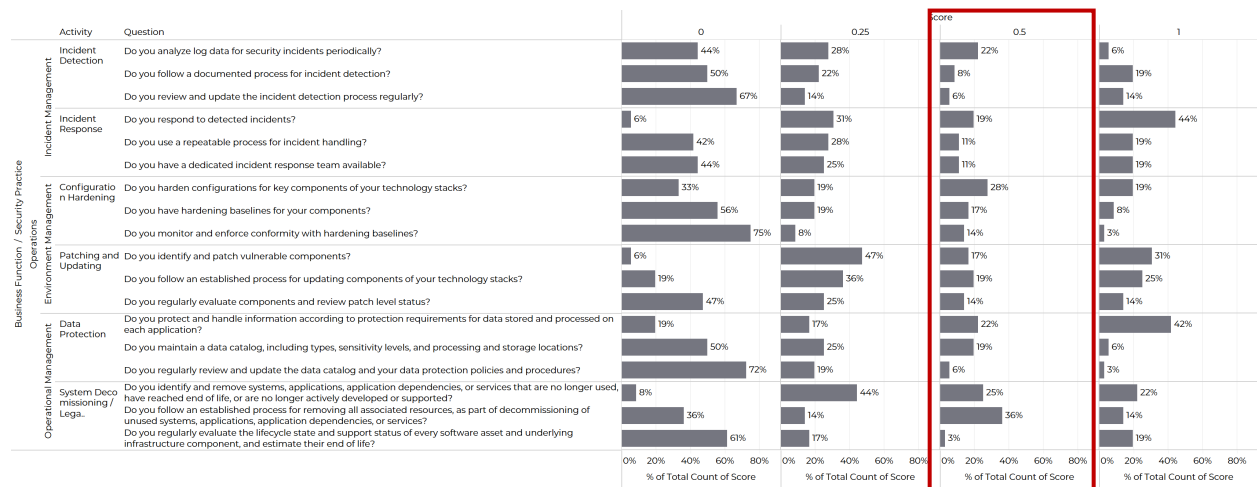


Figure 32: Operations Questions with only Small and Medium Companies

Data Protection is an interesting area to explore. As expected, large companies generally score better at building and maintaining a data catalog, including data classification and the other metadata typically included. However, the difference in scores between large companies and small to medium companies is not as large as one might expect. Companies, large and small, all seem to struggle with trying to determine what data they have in which systems, and how best to protect it.

TAKING ACTION

If you are still reading at this point (or skipped ahead), I'm impressed. Reading through thirty-page reports is no longer common. Maybe I need to make a bunch of TikToks or YouTube Shorts.

You are also probably asking, what can or should I do with this information?

The answer is (as all good answers are) "it depends."

Software development is complex, and securing that software is even more so. There are an insane number of variables that play into which security activities should be implemented in what order. If it was the same for everyone, then we wouldn't really need a model, just a checklist. There are business factors, IT maturity, resources and funding, product goals, expertise, and most importantly, culture.

The best advice I can provide is to find a good SAMM assessor and get an external assessment. A good assessment should essentially be a training opportunity. You should learn about your company during the interview sessions and about what the SAMM model encourages you to implement. If the assessor is just asking the questions from the worksheet, that won't be as effective in my experience. Once you have a good understanding of your current state, develop a plan to make progress; hopefully your assessor has provided a starting point.

While SAMM was built as a symmetrical model and everything is technically weighted the same, in reality, some activities can address higher levels of risk for your company. Again, this is where your SAMM assessor should be able to help identify the areas of focus that pose the highest risk in your scenario. Allocate the resources and make steady progress. Update your scores. Contribute your results and improvements to the SAMM Benchmark data collection so that others can learn from you.

Thank you in advance.

THE MAKING OF THIS REPORT

It pains me to include this part in the report, but AI was neither harmed nor used in its creation. All the images were created by the author in Tableau, as were the narrative and analysis in this document. The extent of any AI in this report is Grammarly constantly reminding me that it doesn't like my writing style. I agreed with a small number of suggestions that improved readability, but generally ignored the rest, as I have developed a dislike of the style and tone of AI-generated content.

Thank you to all the organizations and SAMM practitioners who were willing to share their SAMM assessment results to help improve secure development across the broader community. To mention that it's a challenge to convince organizations to share their assessment results is an understatement. SAMM Benchmark has the potential to help provide invaluable insights into what is working and what challenges organizations are struggling with. We hope to continue growing the SAMM Benchmark project to the point where we can provide detailed, tailored insights for individual companies. Whether or not we can do that depends on you and your willingness to share your assessment results. You can learn more about contributing to the Benchmark section at <https://owaspsamm.org/>.

Author: Brian Glas – SAMM Core Team Member and SAMM Benchmark Lead

Version: Draft v1.0 – 23 June, 2026